HOCHSCHULE MAINZ
Wirtschaft
Business

Modelle und Messbarkeit der Resilienz

Cyber Security Management · Termin 2

Prof. Dr. Dirk Loomans

University of
Applied Sciences

Agenda

- Rückblick & Lernziele
- Einstieg: Brand im Rechenzentrum
- Warum Resilienz messen?
- Resilienz als Systemfunktion: die Degradationskurve
- Kennzahlen: RTO, RPO, MTTR, MTBF – und Verfügbarkeit
- Modelle aus Frameworks (NIST, ISO, BSI, ENISA)
- Messmethoden, KPIs und Reifegrade
- Fallbeispiele & Übung: Resilienz bewerten
- Kernpunkte & Ausblick

Rückblick Sitzung 1

- Resilienz = Widerstands-, Erholungs- **und** Lernfähigkeit – nicht Unverwundbarkeit.
- Safety ≠ Security – beides beeinflusst Resilienz.
- Vier Prinzipien: Redundanz, Diversität, Wiederherstellbarkeit, Adaptivität.
- Die Resilienzkurve: Abfall flacher, Erholung schneller, danach besser.
- Kupferberg: **Ein Backup, das nie getestet wurde, ist eine Hoffnung.**



Lernziele

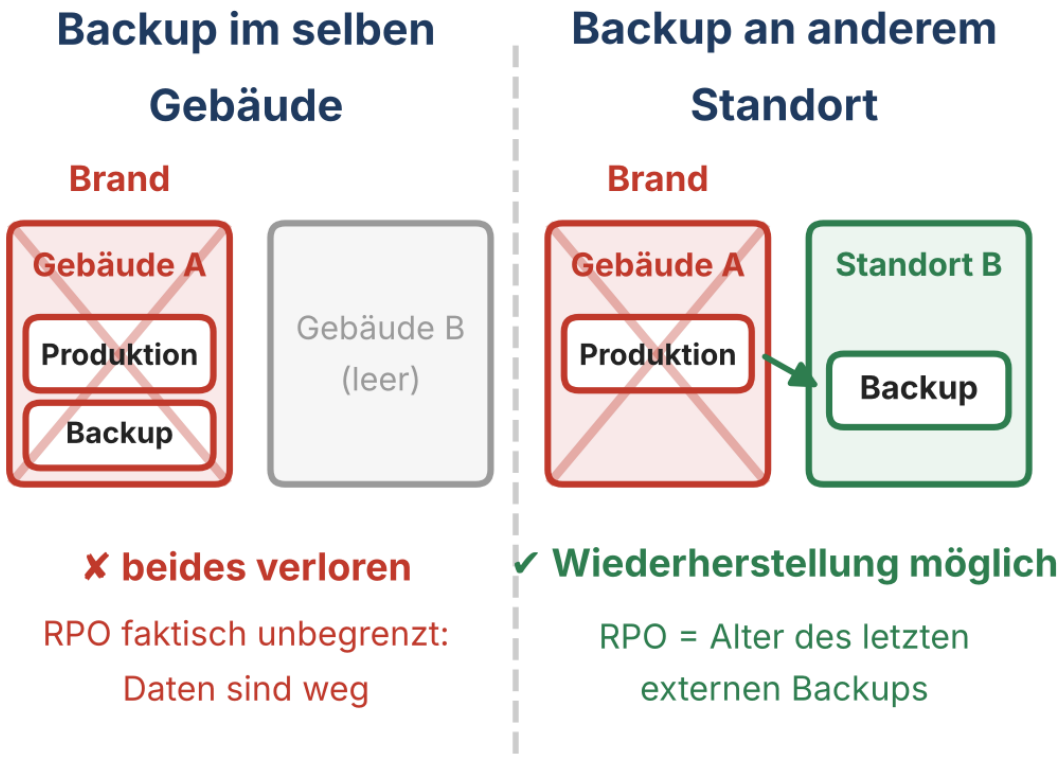
Nach dieser Sitzung können Sie …

– erklären, warum Resilienz **messbar** gemacht werden muss,
– die Kennzahlen **RTO, RPO, MTTR und MTBF** definieren und als Ziel- oder Messwert einordnen,
– Resilienzmodelle in **NIST, ISO/IEC 27031, BSI 200-4 und ENISA** verorten,
– die **Degradations- und Wiederherstellungskurve** eines Systems qualitativ beschreiben,
– erste **Reifegrad- und KPI-basierte Bewertungen** realer IT-Systeme vornehmen.

Einstieg: Brand im Rechenzentrum

- **10. März 2021, Straßburg:** Das Rechenzentrum SBG2 von OVHcloud brennt vollständig aus, SBG1 wird beschädigt
- Betroffen u. a. data.gouv.fr und die Website des Centre Pompidou
- Manche Kunden hatten ihr Backup im **selben Gebäude** wie die Produktion – beides war weg
- 2023 verurteilt ein französisches Handelsgericht OVHcloud zu Schadensersatz, weil Backups nicht wie vereinbart getrennt lagen

Frage: Wie alt dürfen Ihre Daten nach einer Wiederherstellung sein?



Warum Resilienz messen?

- **Steuerung:** Management braucht Kennzahlen für Priorisierung und Budget.
- **Vergleichbarkeit** zwischen Systemen und Organisationen.
- **Frühwarnung:** Indikatoren für Krisenfähigkeit.
- **Nachweis:** In regulierten Domänen (KRITIS, Finanzaufsicht) wird quantifizierbare Belastbarkeit erwartet.

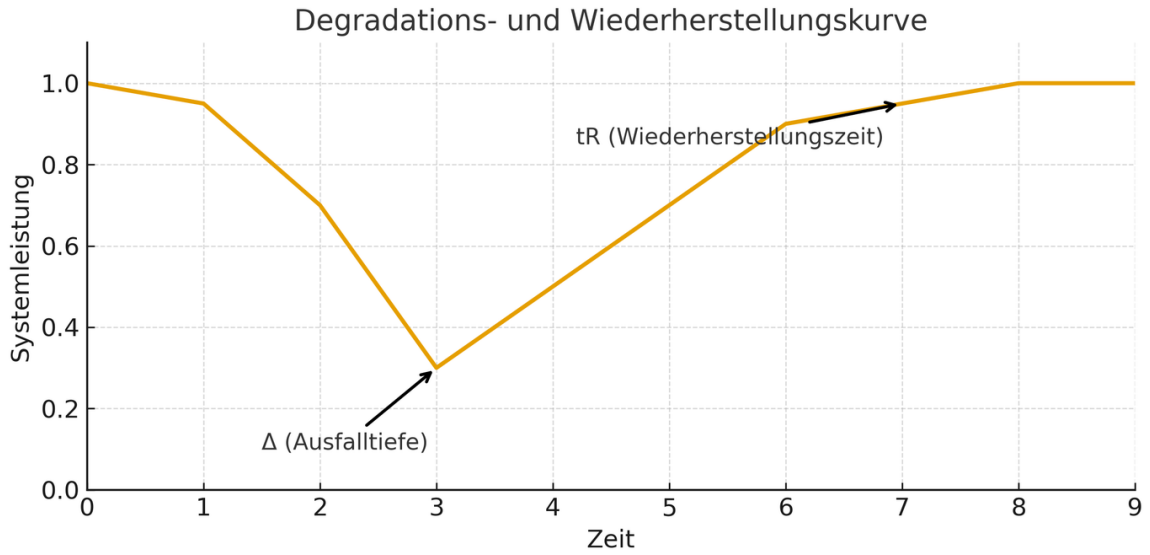
Was man nicht misst, kann man nicht verbessern – und nicht nachweisen.



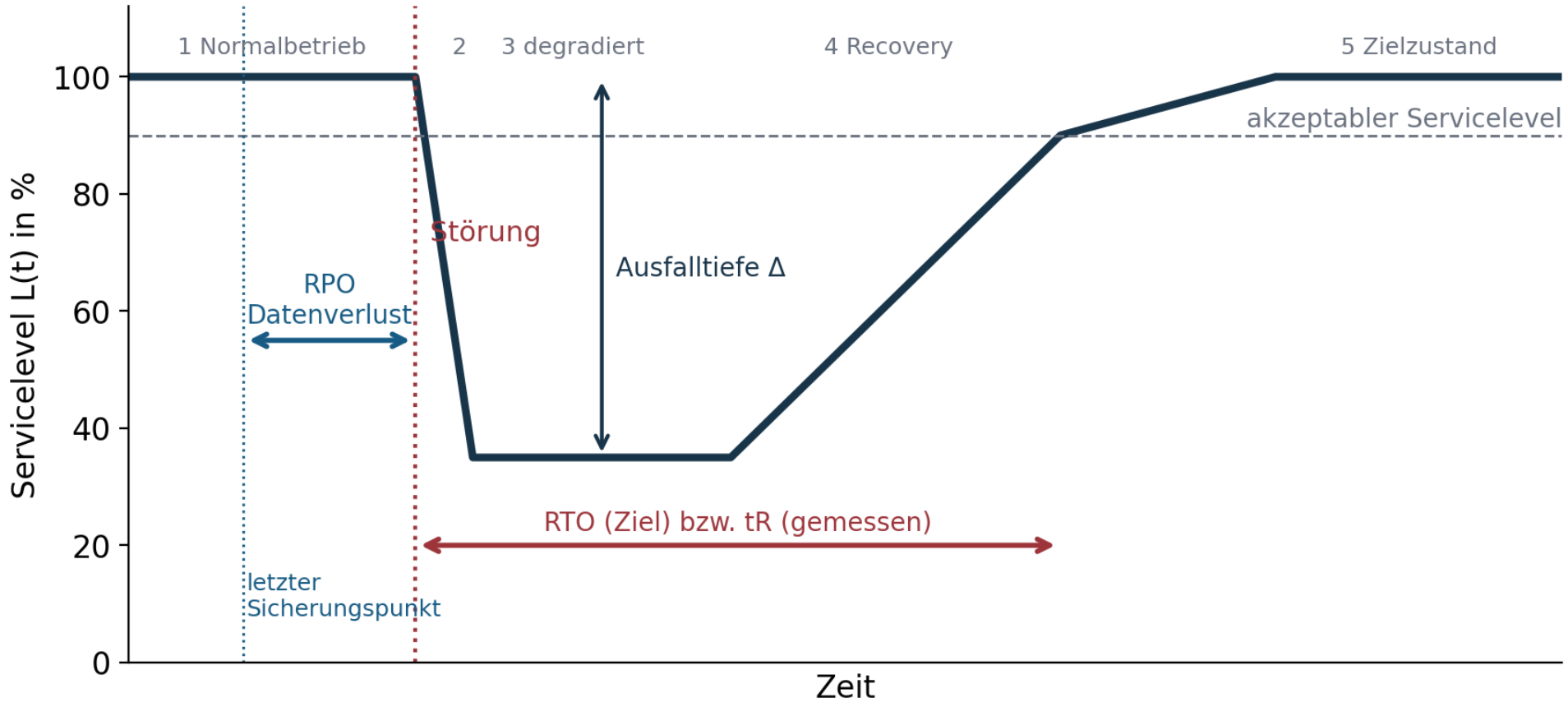
Resilienz als Systemfunktion

- Resilienz ist keine statische Eigenschaft, sondern **Verhalten unter Störung**.
- Systemleistung L(t) über die Zeit → „Degradationskurve“
- Zwei Schlüsselgrößen: **Tiefe des Ausfalls (Δ)** und **Wiederherstellungszeit (tR)**
- Ziel: Minimierung von Δ und tR

Resilienz zeigt sich nicht im Normalbetrieb, sondern in der Auslenkung. Die Kurve misst das Ergebnis, nicht den Weg.



Grafische Darstellung von RTO und RPO



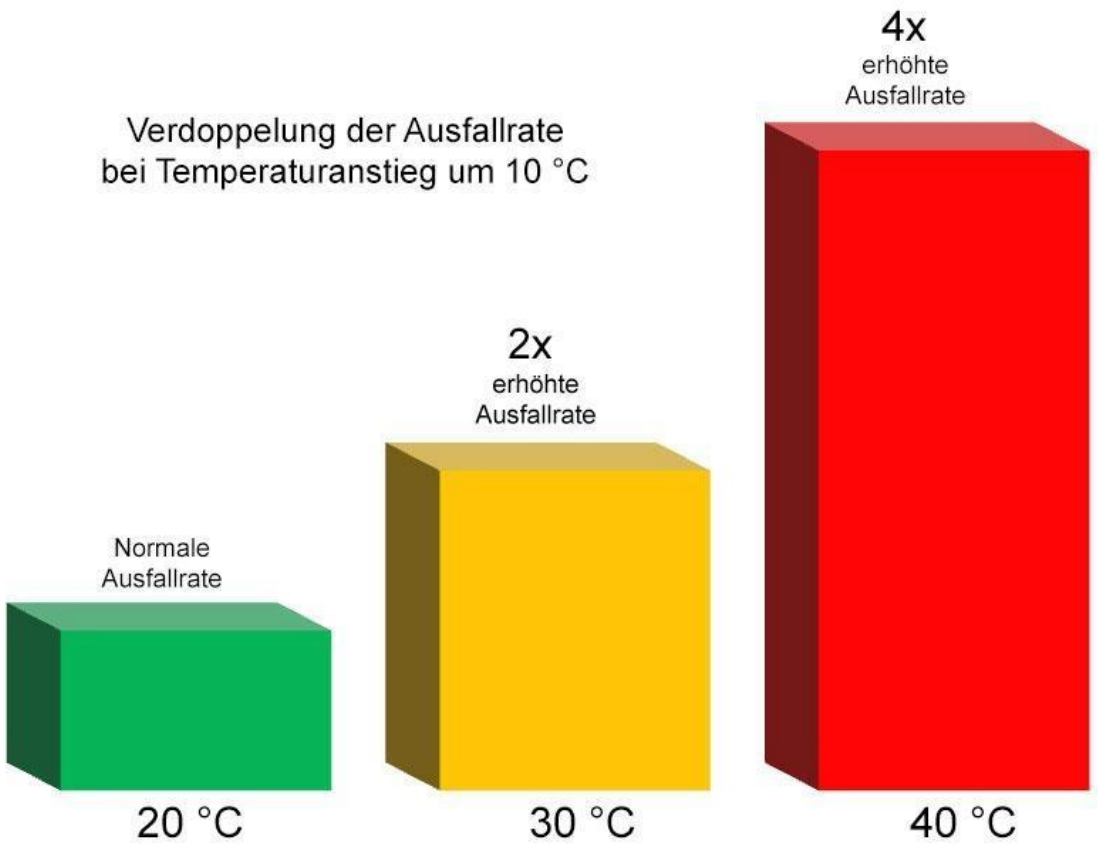
Resilienzmetriken in der IT

RTO und RPO sind Planungsziele, MTTR und MTBF beobachtete Messwerte.

Kennzahl	Bedeutung	Beispiel
RTO	Recovery Time Objective – max. zulässige Wiederherstellungszeit	2 h für Mailserver
RPO	Recovery Point Objective – max. Datenverlust zeitlich	15 min
MTTR	Mean Time to Repair – durchschnittliche Reparaturzeit	45 min
MTBF	Mean Time Between Failures – mittlere Zeit zwischen Fehlern	30 Tage

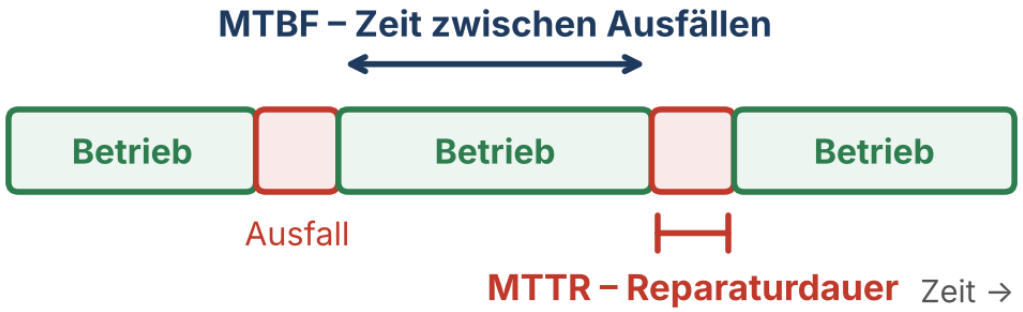
Ziel vs. Messwert

- **RTO / RPO:** normative bzw. vertragliche Anforderung – „Wie lange dürfen wir offline sein? Wie alt dürfen die Daten sein?“
- **MTTR / MTBF:** beobachtete Realwelt-Performance.
- MTBF misst Zuverlässigkeit, nicht Resilienz – ist aber entscheidend für die Risikoexposition.
- Normen fordern **Angemessenheit**, nicht absolute Minimierung.



Verfügbarkeit: MTBF und MTTR zusammen

Verfügbarkeit	Ausfall pro Jahr
99 %	ca. 3,7 Tage
99,9 %	ca. 8,8 Stunden
99,99 %	ca. 53 Minuten
99,999 %	ca. 5 Minuten

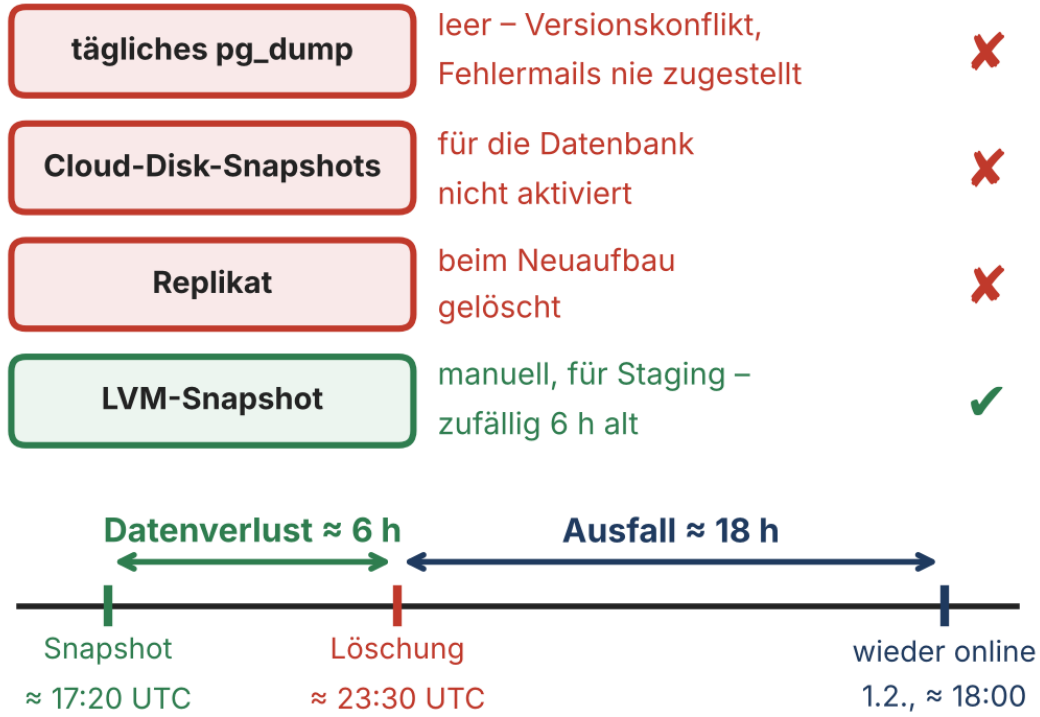


Verfügbarkeit A = MTBF ÷ (MTBF + MTTR)

Beispiel: MTBF 30 Tage, MTTR 45 min → A ≈ 99,9 %

Ein RPO, das niemand prüfte: GitLab 2017

- Am 31. Januar 2017 löscht ein Administrator versehentlich rund 300 GB auf der **Produktionsdatenbank** statt auf dem Replikat
- Vier Sicherungswege – drei versagen unbemerkt
- Rettung durch einen **zufälligen** Snapshot, 6 Stunden alt
- Ergebnis: ca. 6 h Datenverlust, ca. 18 h Ausfall von GitLab.com
- Ursache laut Postmortem: Niemand war für die Backups verantwortlich, niemand testete sie



Modelle aus Frameworks

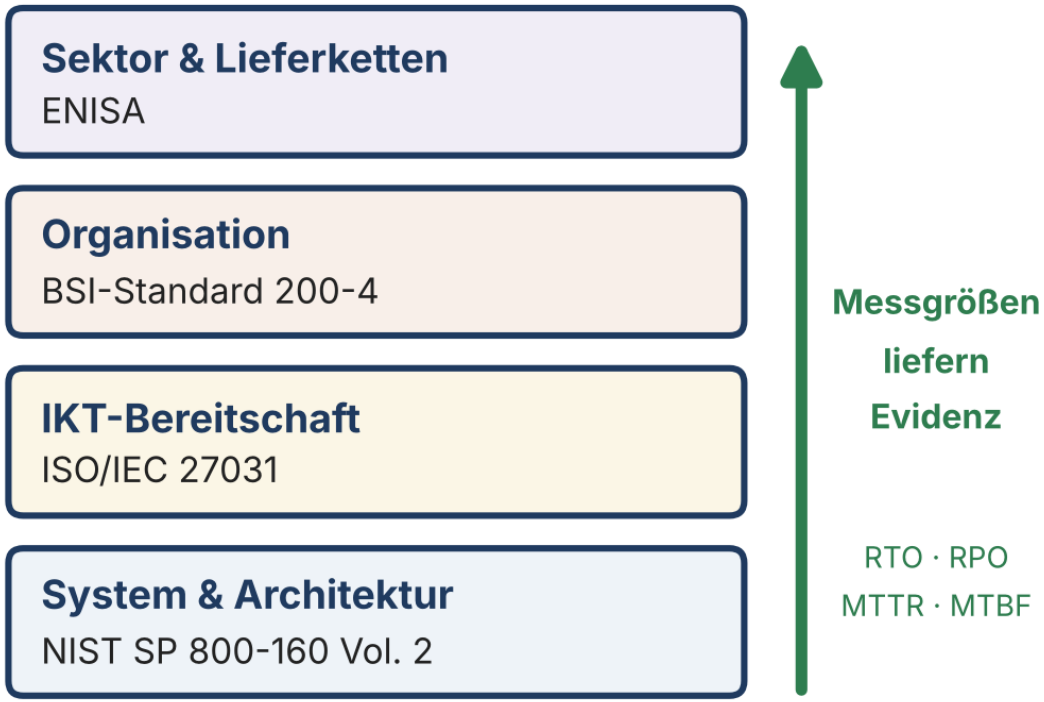
Frameworks liefern den Ordnungsrahmen, in dem Metriken geplant und bewertet werden.

Framework	Fokus	Kernelemente
NIST SP 800-160 Vol. 2	Cyber Resilience Engineering	Rev. 1: Anticipate, Withstand, Recover, Adapt
ISO/IEC 27031	IKT-Bereitschaft für BC	Vorbereitung, Tests, Wiederherstellung
BSI-Standard 200-4	Business Continuity Management	Stufenmodell, Szenarien, Notfallübungen
ENISA	Sektorale Resilienz (KRITIS)	Bedrohungsmodelle, Abhängigkeiten

Messgrößen und Frameworks

Messgrößen erzeugen Evidenz – Frameworks verankern sie strukturell.

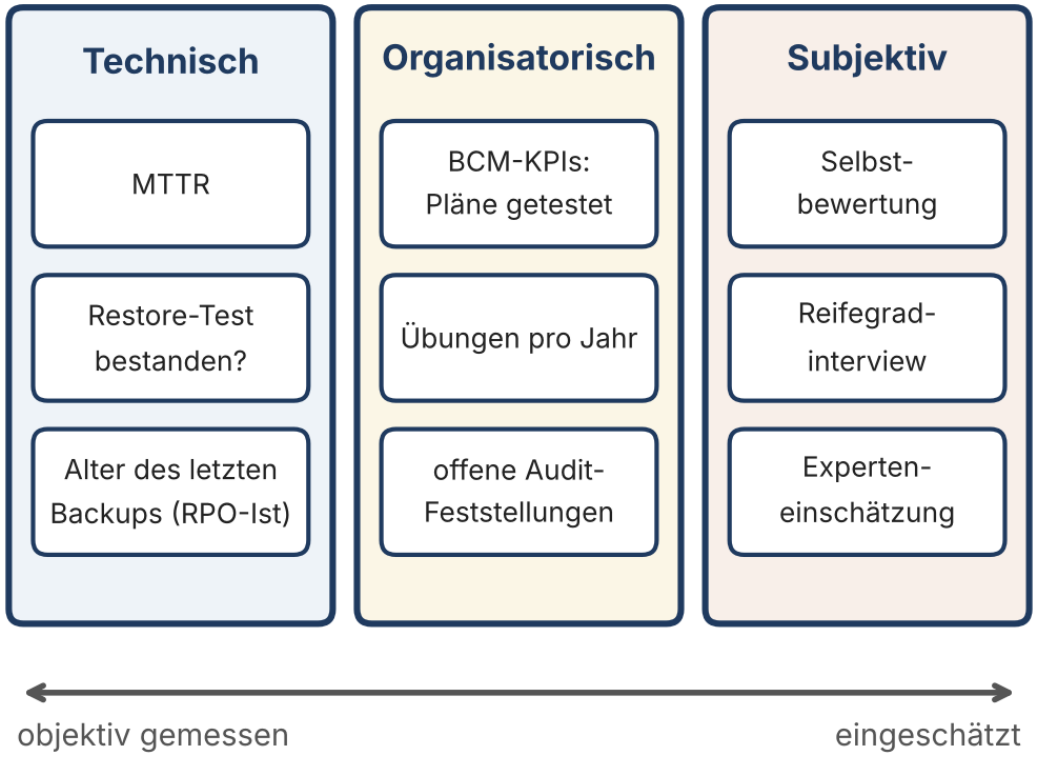
- NIST: Resilienz von Anfang an in Engineering und Architektur
- ISO/IEC 27031: Nachweis- und Testbarkeit statt Dokumentation
- BSI 200-4: bewertet **Organisationen**, nicht nur Systeme
- ENISA: Resilienz über Einzelsysteme hinaus – Lieferketten, KRITIS-Sektoren



Messmethoden & KPIs

- **Technisch:** Monitoring, MTTR, Backup- und Restore-Tests
- **Organisatorisch:** BCM-KPIs, Audit-Indikatoren
- **Subjektiv:** Selbstbewertungen, Reifegradanalysen

Je weiter rechts, desto leichter zu erheben – und desto anfälliger für Schönfärberei.

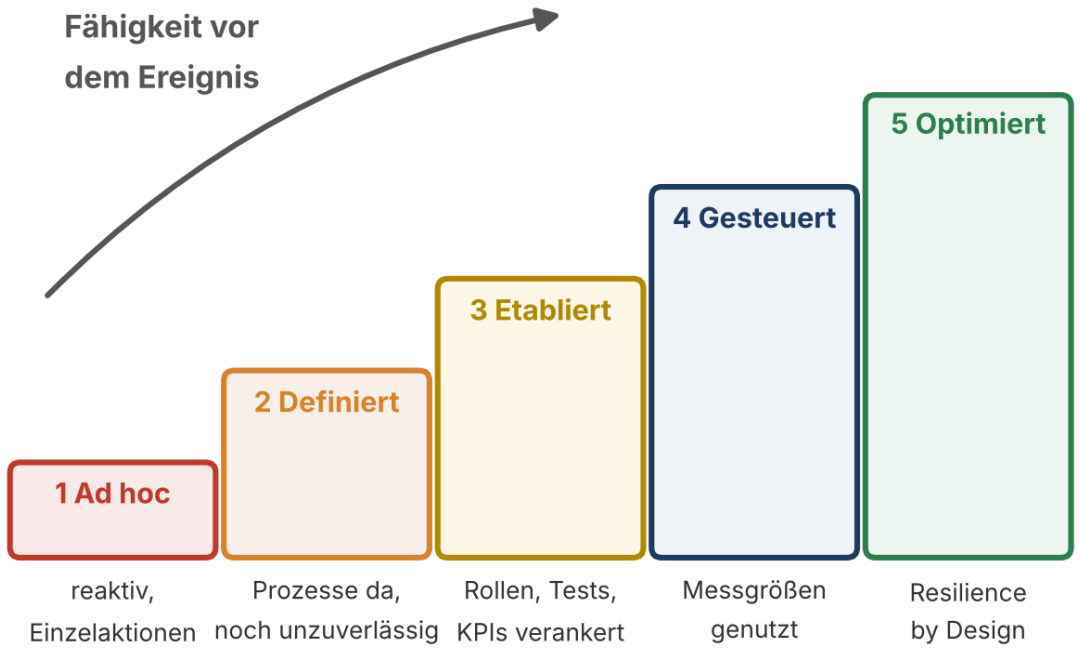


Resilienzreife (Maturity)

Typischer Entwicklungspfad in fünf Stufen:

1. **Ad hoc** – reaktive Einzelaktionen
2. **Definiert** – Prozesse existieren, wirken noch nicht zuverlässig
3. **Etabliert** – Rollen, Tests, Nachweise, KPIs verankert
4. **Gesteuert** – Messgrößen werden genutzt, Lessons Learned
5. **Optimiert** – kontinuierliche Verbesserung, Resilience by Design

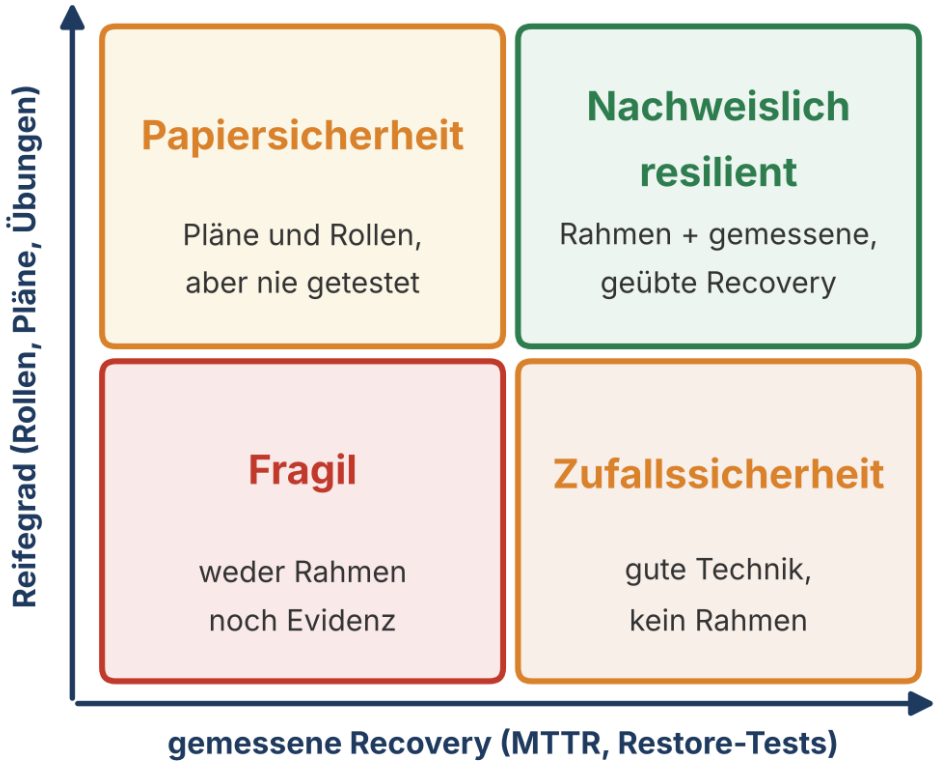
Reifegrad = Fähigkeit *vor* dem Ereignis, nicht Performance danach.



Reifegrad und Metrik

– RTO-Ziel existiert, Recovery-Test nie durchgeführt → geringer Reifegrad trotz Kennzahl.
– MTTR sinkt über die Zeit → Hinweis auf lernende Organisation.
– RPO definiert und Backups getestet → Evidenz statt Policy.

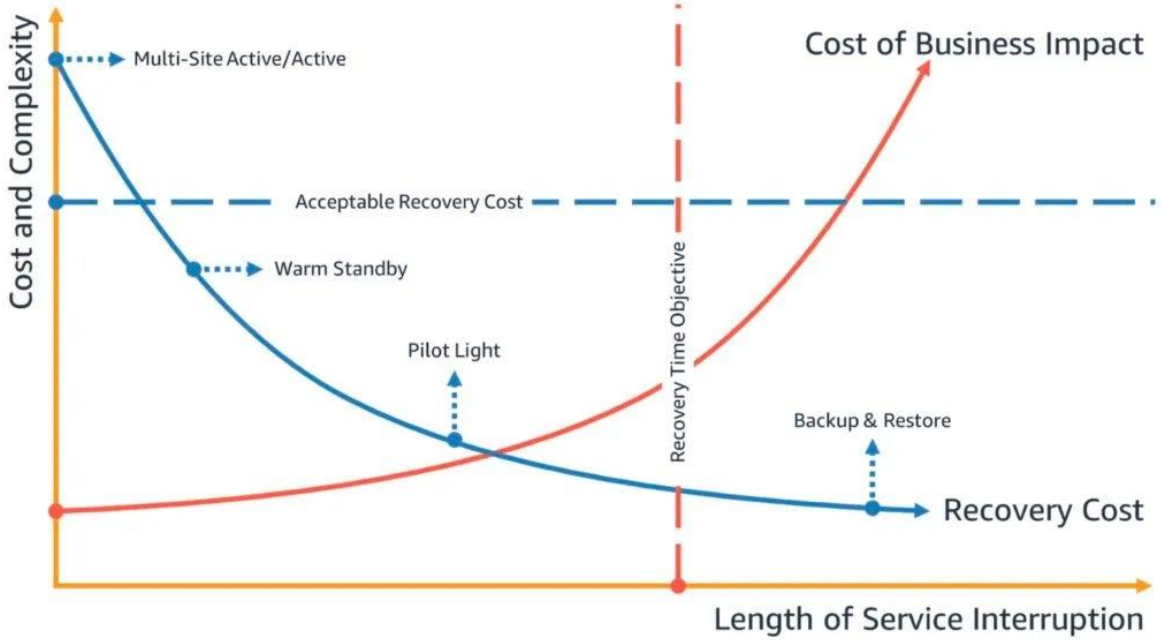
Hoher Reifegrad ohne gemessene Recovery ist Papiersicherheit; gemessene MTTR ohne organisatorischen Rahmen ist Zufallssicherheit.



Fallbeispiel Cloud-Ausfall: AWS 2021

- **7. Dezember 2021, Region us-east-1:** Eine automatisierte Skalierung überlastet das interne AWS-Netz
- Netz rund 7 h gestört, einzelne Dienste bis zu 11 h
- Laufende Instanzen arbeiten weiter – **neue** starten nicht; auch Monitoring und Statusseite sind beeinträchtigt
- Single-Region-Kunden offline, Multi-Region-Kunden schwenken um

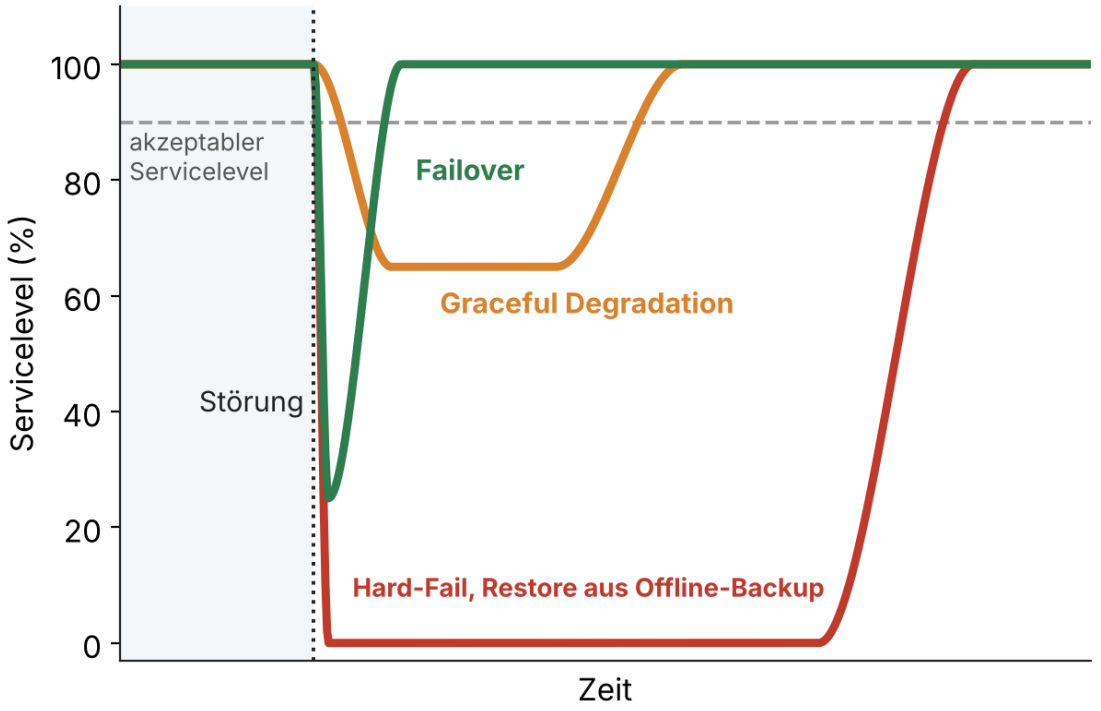
Architektur, nicht Plattform, entscheidet über Resilienz.



Gleiche Störung, andere Kurve

- **Ransomware in einer Kommunalverwaltung:** Totalausfall, mehrtägiger Notbetrieb, Restore nur aus Offline-Backups – niedrige Resilienz trotz vorhandener Backups
- **Multi-Region-Failover:** kurzer Einbruch, nach Minuten zurück
- **Cloud-Gaming-DDoS:** langsamer statt ausgefallen (Rate-Limiting, Warteschlangen) – Graceful Degradation statt Hard-Fail

Resilienz bewertet nicht, ob ein Ereignis eintritt, sondern wie ein System danach aussieht.



Übung: Resilienz bewerten

Gruppenarbeit (20–30 Minuten): Wählt ein bekanntes IT-System – Uni-E-Mail, Cloud-Speicher, Banking-App, Cloud-Gaming, Krankenhaus- oder Verwaltungs-IT, Smart Home.

1. **Metriken schätzen:** Welches RTO, welches RPO wäre angemessen? Ist die MTTR aus Statusseiten oder Incidents erkennbar?
2. **Reifegrad einordnen:** ad hoc oder vorbereitet? Hinweise auf Übungen, DR-Tests, Chaos Engineering? Single Points of Failure?
3. **Fazit:** resilient, bedingt resilient oder fragil – und warum?

Ergebnis: 1–2 Folien oder höchstens fünf Stichpunkte je Dimension.

Bewertungsraster für die Übung

Das Raster hilft, die drei Schritte der Übung strukturiert festzuhalten.

Dimension	Leitfrage	Ihre Einschätzung
RTO	Wie lange darf der Dienst ausfallen?	
RPO	Wie viel Datenverlust ist tolerierbar?	
MTTR	Wie schnell kam der Dienst bisher zurück?	
Reifegrad	Stufe 1–5, mit Begründung	
Matrix-Feld	Fragil, Papier-, Zufallssicherheit oder resilient?	

Kernpunkte

- Resilienz zeigt sich **nicht im Normalbetrieb**, sondern im Verlauf von Störung und Wiederherstellung.
- **RTO/RPO sind Zielgrößen, MTTR/MTBF Messgrößen** – beide sind notwendig.
- Frameworks (NIST, ISO, BSI, ENISA) schaffen Verbindlichkeit und Vergleichbarkeit.
- Reifegradmodelle bewerten die **Fähigkeit vor dem Ereignis**.
- Ein Ziel ohne Test ist Papier: Erst der Restore zeigt das echte RPO.

Ausblick & Hausaufgabe

Nächste Sitzung: Resilienz-Architekturen – Redundanz, Diversität, Wiederherstellbarkeit und Adaptivität in hybriden Systemen (On-Prem + Cloud).
Hausaufgabe: Recherchieren Sie ein reales IT-Ereignis (z. B. AWS-Ausfall, Ransomware-Vorfall, Rechenzentrumsbrand). Wie schnell wurde der Dienst wiederhergestellt (tR), welche Daten gingen verloren (RPO-Ist)? Zeichnen Sie die Kurve.
Kapitel zum Termin · Skript · Glossar · Quellen